

Wapiti vulnerability report

Target: <https://nexastore-market.vercel.app/>

Date of the scan: Tue, 01 Sep 2026 20:27:09 +0000; Scope of the scan: folder. Crawled pages: 51

Summary

Category	Number of vulnerabilities found
Backup file	0
Cleartext Submission of Password	0
Weak credentials	0
CRLF Injection	0
Content Security Policy Configuration	1
Cross Site Request Forgery	0
Fingerprint dangerous file	0
Command execution	0
Path Traversal	0
Fingerprint web application framework	0
Fingerprint web server	0
Htaccess Bypass	0
HTML Injection	0
Clickjacking Protection	1
HTTP Secure Transport Security (HSTS)	0
MIME Type Confusion	1
HttpOnly Flag cookie	0
Unencrypted Channels	0
Insecure Redirection	1
Information Disclosure - Full Path Disclosure	0
LDAP Injection	0
Log4Shell	0
Open Redirect	0
Reflected Cross Site Scripting	0
Secure Flag cookie	0
SpringShell	0
SQL Injection	0
TLS/SSL misconfigurations	5
Server Side Request Forgery	0
Stored HTML Injection	0
Stored Cross Site Scripting	0
Subdomain takeover	0
Blind SQL Injection	0
Unrestricted File Upload	0
Vulnerable software	0
Internal Server Error	0
Resource consumption	0
Review Webservice Metafiles for Information Leakage	0
Fingerprint web technology	0
HTTP Methods	0

Category	Number of vulnerabilities found
TLS/SSL misconfigurations	8

Content Security Policy Configuration

Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks.

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) [command line](#)) [WSTG Code](#)

CSP is not set for URL: `https://nexastore-market.vercel.app/`

Solutions

Configuring Content Security Policy involves adding the Content-Security-Policy HTTP header to a web page and giving it values to control what resources the user agent is allowed to load for that page.

References

- [Mozilla: Content Security Policy \(CSP\)](#)
 - [OWASP: Content Security Policy Cheat Sheet](#)
 - [OWASP: How to do Content Security Policy \(PDF\)](#)
 - [OWASP: Content Security Policy](#)
-

Clickjacking Protection

Description

Clickjacking is a technique that tricks a user into clicking something different from what the user perceives, potentially revealing confidential information or taking control of their computer while clicking on seemingly innocuous objects.

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) [command line](#)) [WSTG Code](#)

X-Frame-Options is not set

Solutions

Implement X-Frame-Options or Content Security Policy (CSP) frame-ancestors directive.

References

- [OWASP: Clickjacking](#)
- [KeyCDN: Preventing Clickjacking](#)

MIME Type Confusion

Description

MIME type confusion can occur when a browser interprets files as a different type than intended, which could lead to security vulnerabilities like cross-site scripting (XSS).

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

X-Content-Type-Options is not set

Solutions

Implement X-Content-Type-Options to prevent MIME type sniffing.

References

- [OWASP: MIME Sniffing](#)
- [KeyCDN: Preventing MIME Type Sniffing](#)

Inconsistent Redirection

Description

An HTTP 3xx redirection response should typically contain only minimal content (or none), as clients are expected to follow the Location header. However, this response also contains HTML content (such as links or forms). This may confuse clients, expose unintended information, or allow attackers to craft malicious redirections.

Vulnerability found in /cart

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

3xx redirection contains unexpected HTML body (links/forms)

Solutions

Ensure that 3xx HTTP responses only return the appropriate redirection headers and do not include unnecessary HTML body content. If user feedback is required, provide a clear message without interactive elements (like forms or links). Always rely on the Location header to redirect the request.

References

- [ZAP Alert 10044-1: Inconsistent Redirection](#)
 - [MDN: HTTP Redirections](#)
 - [WSTG: Review Webpage Content for Information Leakage](#)
-

TLS/SSL misconfigurations

Description

The TLS protocol aims primarily to provide privacy and data integrity between two or more communicating computer applications. Over the years numerous vulnerabilities have been discovered in some SSL/TLS version or specific ciphers making the integrity of the communications at risk (eavesdropping, alteration...)

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Certificate doesn't use Extended Validation

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

OCSP Must-Staple extension is missing

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Strict Transport Security (HSTS) is not set

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Server is vulnerable to OpenSSL CCS (CVE-2014-0224)

Vulnerability found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Server doesn't support secure renegotiations

Solutions

To protect against SSL/TLS vulnerabilities, make sure that deprecated versions of the protocol are disabled. Refer to up-to-date recommendations to only allow modern versions of TLS with Perfect Forward Secrecy.

References

- [SSL Labs: SSL and TLS Deployment Best Practices](#)
- [Mozilla Server Side TLS recommended configurations](#)
- [Beast: Security: Importance of TLS 1.3, SSL and TLS Vulnerabilities](#)
- [Security of TLS cipher suites](#)
- [Trail of Bits: What Application Developers Need To Know About TLS Early Data \(0RTT\)](#)
- [OWASP: Weak SSL TLS Ciphers Insufficient Transport Layer Protection](#)

TLS/SSL misconfigurations (Additional)

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Certificate subject: *.vercel.app

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Alt. names: *.vercel.app

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Issuer: WR1

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Key: RSA 2048 bits

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Signature Algorithm: sha256WithRSAEncryption

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

Certificate expires in about 88 days, 23 hours and 19 minutes

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

The following ciphers are strong for TLSv1.3: TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_CHACHA20_POLY1305_SHA256

Additional found in /

[Description](#) [HTTP Request](#) ([URL](#) command line) [WSTG Code](#)

The following ciphers are strong for TLSv1.2: TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256

Solutions

To protect against SSL/TLS vulnerabilities, make sure that deprecated versions of the protocol are disabled. Refer to up-to-date recommendations to only allow modern versions of TLS with Perfect Forward Secrecy.

References

- [SSL Labs: SSL and TLS Deployment Best Practices](#)
- [Mozilla Server Side TLS recommended configurations](#)
- [Beast: Security: Importance of TLS 1.3, SSL and TLS Vulnerabilities](#)

- [Security of TLS cipher suites](#)
- [Trail of Bits: What Application Developers Need To Know About TLS Early Data \(0RTT\)](#)
- [OWASP: Weak SSL TLS Ciphers Insufficient Transport Layer Protection](#)